

INGENIERÍA EN COMPUTACIÓN



SEGURIDAD INFORMÁTICA BÁSICA

TRABAJO: INVESTIGACIÓN

INTEGRANTES:
CHILPA NAVARRO ALAN SALVADOR- 319207738
MEDINA RUBALCAVA NATALIA MICHELL - 319207336
MURILLO RODRÍGUEZ SARAH SOFIA- 422130448
ORTEGA DE LA PAZ RAFAEL - 420054085
ROMERO GARCÍA DIANA SOFÍA - 319339264

GRUPO : 2

SEMESTRE: 2027-1

PROFESORA: DRA. CINTIA QUEZADA REYES

FECHA: 20 DE OCTUBRE DE 2026

1. Ataques a redes telefónicas

- **¿Qué es?**
  Son ataques dirigidos a los sistemas de comunicación telefónica, tanto tradicionales como digitales. Buscan interceptar llamadas, robar información, suplantar números telefónicos o interrumpir el servicio.
- **Características principales**
  - **Intercepción de llamadas:** permite obtener información de conversaciones telefónicas sin autorización.
  - **Suplantación telefónica:** se falsifica el número de origen para engañar al receptor de una llamada.
  - **Ataques a VoIP:** aprovechan vulnerabilidades en los sistemas que transmiten llamadas por Internet.
  - **Fraude telefónico:** se utilizan líneas o servicios telefónicos sin permiso para generar llamadas y cargos.
  - **Denegación de servicio:** consiste en saturar una red telefónica para impedir que los usuarios realicen llamadas.
- **¿Por qué es importante?**
  - Permite identificar vulnerabilidades en los sistemas de comunicación.
  - Ayuda a proteger la privacidad de las conversaciones y la información personal.
  - Evita pérdidas económicas relacionadas con llamadas fraudulentas.
  - Garantiza una mayor disponibilidad de los servicios telefónicos.



2. Ataques a telefonía inalámbrica

- **¿Qué es?**
  Son ataques que afectan las comunicaciones de dispositivos móviles conectados a redes celulares, como 2G, 3G, 4G y 5G. Su objetivo puede ser obtener información, interceptar comunicaciones o afectar la conectividad.
- **Características principales**

    - **Intercepción de señales:** captura de información transmitida entre dispositivos y estaciones base.
    - **Estaciones base falsas:** simulan ser antenas legítimas para intentar obtener información de los dispositivos cercanos.
    - **SIM swapping:** consiste en transferir fraudulentamente el número telefónico de una víctima a otra tarjeta SIM.
    - **Ataques a protocolos:** aprovechan debilidades de seguridad presentes en tecnologías celulares antiguas.
    - **Interferencia de señales:** puede provocar interrupciones en las llamadas y conexiones móviles.
- **¿Por qué es importante?**
    - Protege la información personal que se transmite mediante redes móviles.
    - Permite detectar amenazas que comprometen la privacidad de los usuarios.
    - Ayuda a prevenir el robo de identidad y el acceso no autorizado a cuentas.
    - Favorece el desarrollo de tecnologías celulares con mejores mecanismos de seguridad.

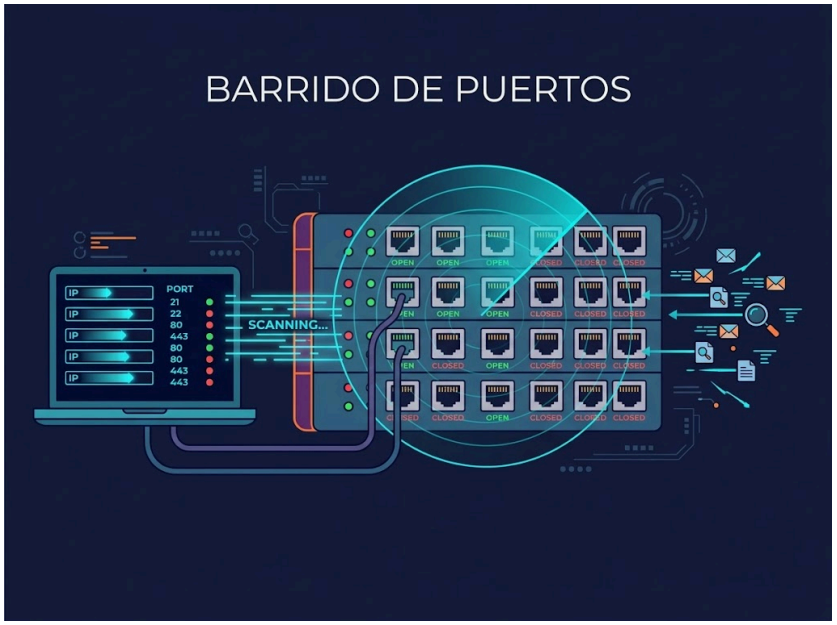


3. Barrido de puertos

- **¿Qué es?**
  Es una técnica utilizada para identificar los puertos abiertos, cerrados o filtrados de un dispositivo conectado a una red. Permite conocer qué servicios están disponibles y detectar posibles puntos vulnerables.
- **Características principales**
    - **Identificación de puertos:** permite descubrir qué puertos están abiertos y disponibles para recibir conexiones.
    - **Escaneo TCP:** analiza los puertos que utilizan el protocolo TCP para establecer comunicaciones.

- **Escaneo UDP:** revisa servicios que utilizan UDP, como DNS, aunque sus resultados pueden ser menos concluyentes.
- **Herramientas especializadas:** se utilizan programas como Nmap para realizar análisis de puertos.
- **Detección de servicios:** permite identificar aplicaciones y, en algunos casos, sus versiones.

- **¿Por qué es importante?**
  - Ayuda a detectar servicios innecesarios que podrían representar un riesgo.
  - Permite comprobar si los puertos de una red están correctamente protegidos.
  - Facilita la identificación de vulnerabilidades antes de que sean aprovechadas.
  - Es una actividad fundamental en las auditorías de seguridad y pruebas de penetración.



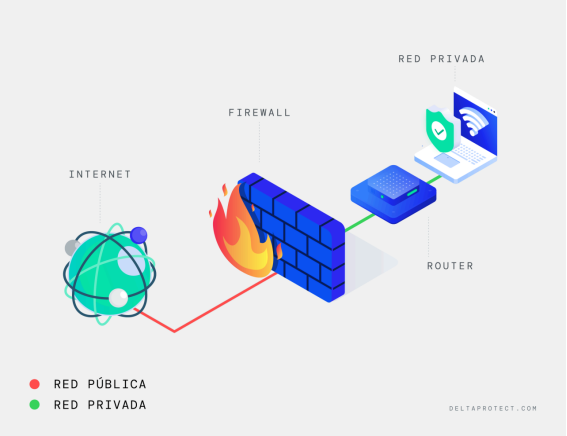
4. Identificación de firewalls

- **¿Qué es?**

  Son las técnicas para descubrir si hay un firewall protegiendo una red o un equipo, y para averiguar de qué tipo es, qué versión tiene y qué tráfico permite o bloquea. Los firewalls son la primera línea de defensa de una organización y pueden ser de software o de hardware.

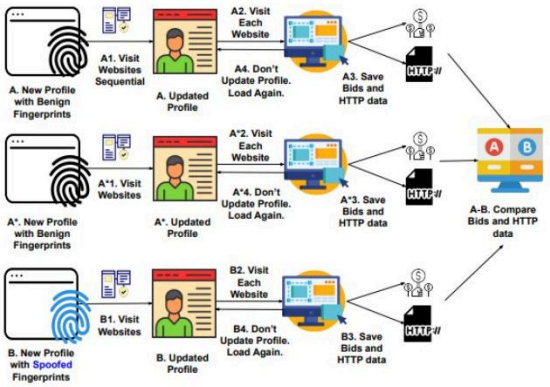
- **Características principales**
  - **Localizar el firewall:** se escanea la red con herramientas como Nmap y Hping, que muestran puertos abiertos, servicios y versiones.
  - **Banner grabbing:** se lee el mensaje de presentación que devuelve un servicio, que suele revelar la versión del firewall.
  - **Lectura de respuestas:** un puerto **“filtered”** significa que el firewall lo bloqueó y uno **“unfiltered”** que deja pasar el tráfico. Un RST/ACK indica que

rechazó el paquete, la falta de respuesta que lo descartó, y un ICMP tipo 3 código 13 que bloqueó la conexión.
    - **Firewalking:** usa valores TTL y técnicas parecidas a traceroute para mapear los dispositivos detrás del firewall.
    - **Deja rastro:** como envía paquetes al objetivo, normalmente queda registrado en los logs.
    - **Consiste de 13 pasos:**
        1. Localizando el cortafuegos
        2. Realizando traceroute
        3. Escaneando puertos
        4. Nanner agarrando
        5. Enumeración de control de acceso
        6. Identificación de la arquitectura del firewall
        7. Probando la política del cortafuegos
        8. Caminar sobre brasas
        9. Redirección de puerto
        10. Pruebas internas y externas
        11. Pruebas para canales encubiertos
        12. Túnel HTTP
        13. Identificación de vulnerabilidades específicas del cortafuegos.
- **¿Por qué es importante?**
    - Permite comprobar si el firewall está bien configurado y si sus reglas hacen lo que se espera
    - Ayuda a ver cuánta información revela el propio firewall sin querer y a reducirla.
    - Conocer la versión sirve para encontrar vulnerabilidades ya conocidas de ese producto, tanto para corregirlas como, en manos de un atacante, para aprovecharlas.
    - Es un paso estándar en las pruebas de penetración a firewalls.



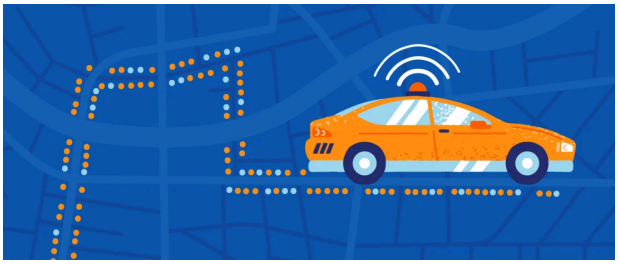
5. Fingerprinting

- **¿Qué es?**
  Significa **"huella digital"**. Es la técnica para identificar el sistema operativo de un equipo remoto, y a veces la versión de sus servicios, analizando cómo se comporta. Funciona porque cada sistema operativo implementa TCP/IP con pequeñas diferencias, y los estándares (RFC) no obligan a usar un valor concreto en campos como el TTL o el tamaño de ventana TC.
- **Características principales**
  - **Activo**: envía paquetes preparados y analiza las respuestas. Es más fácil y da mejores resultados, pero genera tráfico que puede detectarse. Hoy casi todo se hace con Nmap.
  - **¿Qué analiza el activo?**: banderas TCP, tamaño de ventana, tiempo de retransmisión, orden de las opciones, timestamps y número de secuencia inicial (ISN).
  - **Pasivo:** no envía nada, solo escucha el tráfico existente. Una forma sencilla es mirar el TTL inicial del encabezado IP y el tamaño de ventana TCP del primer paquete de una sesión.
  - **Precisión:** el pasivo es menos exacto que el activo, pero es más difícil de detectar. Distinguir versiones del mismo sistema operativo suele ser complicado.
  - **Herramientas:** Nmap (activo), p0f (pasivo) y SinFP (ambos).
  - **Limitación:** si hay un firewall en medio, Nmap puede terminar identificando al firewall y no al equipo real.
- **¿Por qué es importante?**
  - Saber qué sistema operativo usa un equipo permite elegir pruebas y vulnerabilidades que realmente apliquen, en lugar de probar a ciegas.
  - Ayuda a los administradores a tener un inventario real de su red.
  - Los defensores también deben conocerlo: se recomienda endurecer los sistemas contra el fingerprinting activo y probar la propia red con técnicas activas y pasivas



6. Escaneo a redes inalámbricas

- **¿Qué es?**
  Es el proceso de detectar y analizar las redes Wi-Fi, y otros enlaces como Bluetooth, que hay en un lugar: ¿Qué puntos de acceso existen?, ¿Cómo están configurados? y ¿Qué tan seguros son? La guía NIST SP 800-115 lo incluye como técnica formal de evaluación, con apartados para escaneo pasivo, activo, localización de dispositivos y Bluetooth.
- **Características principales**
  - **Escaneo pasivo:** solo escucha las señales que ya emiten los puntos de acceso, sin transmitir. Es difícil de detectar**.**
  - **Escaneo activo:** envía solicitudes (probes) para provocar respuestas. Obtiene más datos, pero deja más rastro.
  - **Wardriving:** se recorre una zona a pie o en auto con un sensor inalámbrico para localizar redes, redes falsas (rogue) y redes mal configuradas. Puede perder puntos de acceso que estaban apagados**.**
  - **Datos que recopila:** nombres de red (SSID), ubicación por GPS y tipo de seguridad. Herramientas conocidas: Kismet, NetStumbler y MiniStumbler.
  - **Requiere autorización:** solo debe hacerse con permiso del dueño de la red.
- **¿Por qué es importante?**
  - Las señales Wi-Fi no se detienen en las paredes, así que cualquiera cerca del edificio puede ver esas redes.
  - Permite encontrar puntos de acceso no autorizados, redes abiertas o con cifrado débil antes de que alguien los aproveche.
  - Forma parte de las evaluaciones de seguridad que recomienda NIST, junto con el descubrimiento de red y el escaneo de vulnerabilidades.
  - El entorno de radio cambia constantemente, por lo que conviene repetir los escaneos.



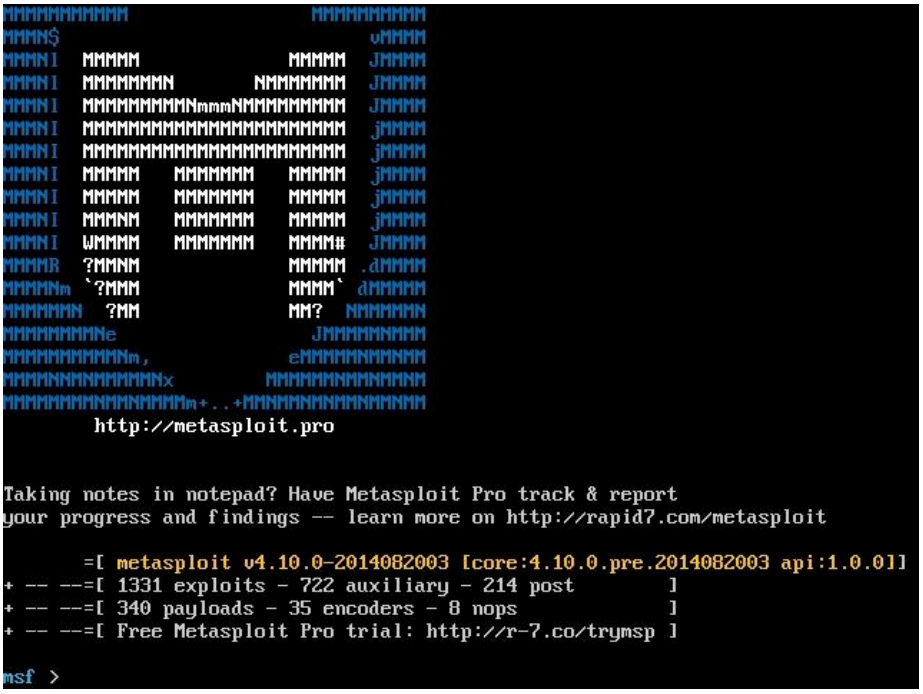


7. Metasploit

- **¿Qué es?**
  Metasploit es un framework de código abierto para pruebas de penetración. Lo creó H.D. Moore en 2003 y hoy lo mantiene Rapid7. Está escrito principalmente en Ruby y permite a los especialistas verificar si una vulnerabilidad es realmente explotable, en lugar de solo reportarla como posible.

- **Características principales**
  - Módulos organizados: exploits (aprovechan una vulnerabilidad), payloads (código que se ejecuta tras la explotación), auxiliares (escaneo y fuerza bruta), encoders y módulos de post-explotación.
  - Meterpreter: un payload avanzado que da una sesión interactiva en el equipo comprometido, con funciones para explorar archivos, capturar información y moverse por la red.
  - Interfaces variadas: msfconsole (consola interactiva), msfvenom (generación de payloads) y una interfaz web en la versión comercial.
  - Base de datos integrada: guarda hosts, servicios y vulnerabilidades encontrados durante la prueba**.**
- **¿Por qué es importante?**

Estandariza el proceso de explotación y permite reproducir pruebas de forma consistente. Además, su amplia base de exploits lo convierte en una herramienta de referencia para validar parches y controles de seguridad.



8. Metodología OSSTMM v3

- **¿Qué es?**
  OSSTMM (Open Source Securityj Testing Methodology Manual) es una metodología científica para medir la seguridad de un sistema de forma objetiva y repetible. La versión 3 fue publicada en 2010 por ISECOM (Institute for Security and Open Methodologies), bajo la dirección de Pete Herzog.

- **Características principales**
  - Cinco canales de prueba: humano, físico, inalámbrico, telecomunicaciones y redes de datos.
  - Enfoque en mediciones: utiliza valores RAV (Risk Assessment Values) para calcular el nivel de riesgo operativo, en lugar de una lista de vulnerabilidades.
  - Reporte STAR (Security Test Audit Report): documento que presenta resultados, limitaciones y el alcance real de la prueba.
  - Proceso definido: incluye planeación, ejecución y validación, y se basa en reglas de compromiso y alcance claramente establecidos.
  -

- **¿Por qué es importante?**

Permite comparar la seguridad de una organización a lo largo del tiempo y demostrar que las pruebas se hicieron de manera rigurosa. Al incluir aspectos humanos y físicos, muestra que la seguridad no depende solo de la tecnología.



9. Pentesting

- **¿Qué es?**
  Pentesting (prueba de penetración) es una simulación controlada y autorizada de un ataque informático contra un sistema, con el fin de descubrir vulnerabilidades explotables antes de que lo haga un atacante real.

- **Características principales**
  - Fases comunes: planeación y alcance, reconocimiento, escaneo, explotación, post-explotación y reporte.
  - Tipos según el conocimiento previo: caja negra (sin información previa), caja gris (información parcial) y caja blanca (acceso completo a la documentación y el código).
  - Autorización formal: requiere un contrato o acuerdo que defina qué se puede probar y hasta dónde llegar.
  - Reporte final: incluye vulnerabilidades encontradas, su impacto, su nivel de riesgo y recomendaciones de corrección.
- **¿Por qué es importante?**
- Ayuda a encontrar fallas antes de que sean explotadas, valida la eficacia de los controles de seguridad y apoya el cumplimiento de normas como PCI DSS. También permite priorizar inversiones en seguridad según el riesgo real.



10. Robo de identidad

- **¿Qué es?**
  Es la obtención, transferencia, uso o apropiación indebida de los datos personales de un ser humano sin su autorización, generalmente para cometer un fraude o delito. La identidad se constituye por datos como nombre, domicilio, huellas dactilares, identificaciones oficiales e información financiera.
- **Características principales**
  - **Modalidad física:** se sustrae o extravía identificación oficial y se usa para contratar créditos o servicios a nombre de la víctima.
  - **Modalidad virtual:** se recaban datos sin consentimiento, mediante phishing o filtraciones, para realizar operaciones en línea.

    - **Identidad sintética:** se combinan datos reales y ficticios para crear un perfil no existente con fines de fraude.
    - **Uso de los datos:** apertura de cuentas y líneas de crédito, control de cuentas existentes y compras a nombre de titular.
    - **Técnicas emergentes:** uso de IA para clonar rostro y voz (deepfakes) y así extorsionar o defraudar.
- **¿Por qué es importante?**
    - México se ubica entre los países con mayor incidencia de este delito a nivel mundial.
    - Es una de las reclamaciones más frecuentes ante la CONDUSEF en el sector financiero.
    - Sus consecuencias afectan el patrimonio, el historial crediticio y la privacidad, y son difíciles de revertir.
    - Conocerlo permite prevenirlo y saber ante qué autoridades acudir: CONDUSEF, INAI y Ministerio Público.



11. Ataques a firewalls

- **¿Qué es?**
  Son las acciones dirigidas a vulnerar un firewall, considerado la primera línea de defensa perimetral en una red. Pueden buscar evadir sus reglas para que el tráfico malicioso pase inadvertido, o comprometer el propio dispositivo para interrumpir su servicio o tomar su control, aprovechando debilidades de diseño, configuración o software.
- **Características principales**
    - **Fragmentación de paquete:** reparte los encabezados en varios fragmentos para que los campos que el firewall inspecciona sean más difíciles de analizar.
    - **Uso de puertos de confianza:** envía tráfico por puertos normalmente permitidos, como el 54 (DNS) o el 80 (HTTP), para no levantar sospechas.
    - **Suplantación y señuelos:** usa direcciones IP falsas (spoofing) y señuelos (decoys) para ocultar el origen real del escaneo.

    - **Tunelización (tunneling):** encapsula tráfico no autorizado dentro de protocolos permitidos (HTTP, DNS, ICMP o SSH); es la técnica más potente, pues viaja por un canal de confianza.
    - **Ataques al propio dispositivo:** denegación de servicios (Dos/DDos), explotación de software desactualizado y ataque de capa 7 que lo rodean.
- **¿Por qué es importante?**
    - El firewall concentra la protección del perímetro; si se vulnera, queda expuesta toda la red interna.
    - Conocer estas técnicas permite validar que las reglas funcionen y endurecer la configuración.
    - La mayoría de las brechas se deben a errores de configuración, no a fallas de producto.
    - Es un paso estándar en las pruebas de penetración para medir la resistencia de la defensa.



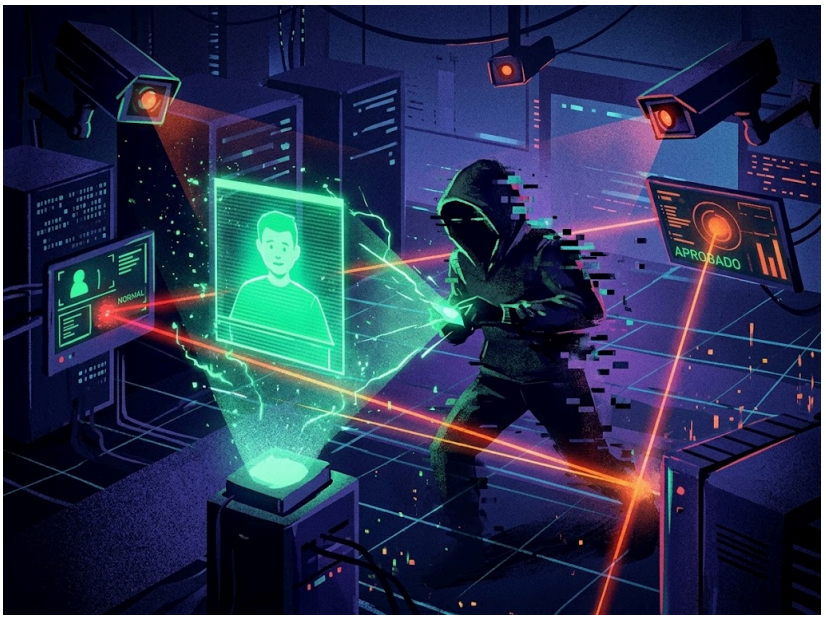
12. Engaño a detectores de intrusos

- **¿Qué es?**
  Técnicas utilizadas para evitar que los sistemas de detección de intrusos (IDS) identifiquen actividades sospechosas o ataques dentro de una red. Buscan ocultar comportamientos maliciosos o provocar interpretaciones incorrectas del tráfico.

- **Características principales**
    - **Evasión de firmas:** modifica patrones del tráfico para evitar que coincidan con amenazas conocidas.
    - **Fragmentación de paquetes:** divide la información transmitida, lo que puede dificultar su análisis si el IDS no reconstruye correctamente el tráfico.
    - **Tráfico cifrado:** puede ocultar el contenido de las comunicaciones frente a sistemas que no pueden inspeccionarlo.
    - **Modificación de tiempos:** altera la frecuencia de las comunicaciones para dificultar su identificación.

- **Generación de falsas alertas:** busca confundir al sistema de seguridad mediante actividad que aparenta ser maliciosa.

- **¿Por qué es importante?**
  - Permite conocer las limitaciones de los sistemas de detección de intrusos.
  - Ayuda a mejorar las reglas de detección y el análisis del tráfico.
  - Reduce el riesgo de que ataques reales pasen desapercibidos.
  - Es importante para evaluar la eficacia de las herramientas de monitoreo y protección de redes.



13. Ataques a contraseñas

- **¿Qué es?**
  Métodos utilizados para descubrir, obtener o descifrar contraseñas con el propósito de acceder a cuentas, dispositivos o sistemas sin autorización. Aprovechan contraseñas débiles, errores humanos o fallas de seguridad.
- **Características principales**
  - **Fuerza bruta:** prueba múltiples combinaciones de caracteres hasta encontrar una contraseña válida.
  - **Ataque de diccionario:** utiliza listas de palabras y contraseñas comunes para intentar acceder a una cuenta.
  - **Phishing:** engaña a los usuarios mediante mensajes o páginas falsas para obtener sus credenciales.
  - **Credential stuffing:** prueba contraseñas filtradas anteriormente en otros servicios.

- **Password spraying:** intenta utilizar una misma contraseña común en diferentes cuentas para evitar múltiples intentos sobre un solo usuario.

- **¿Por qué es importante?**
  - Permite comprender los riesgos de utilizar contraseñas débiles o repetidas.
  - Ayuda a prevenir accesos no autorizados a sistemas y cuentas personales.
  - Promueve el uso de contraseñas seguras y autenticación multifactor.
  - Protege información confidencial y reduce el riesgo de robo de identidad.



14. Debilidades de los protocolos de red

- **¿Qué es?**
  Son vulnerabilidades o limitaciones de seguridad que presentan algunos protocolos utilizados para comunicar dispositivos en una red. Pueden permitir la interceptación de información, la suplantación de dispositivos o la modificación de datos transmitidos.

- **Características principales**
  - **Falta de cifrado:** protocolos como HTTP, FTP y Telnet pueden transmitir información sin protección criptográfica.
  - **Autenticación insuficiente:** algunos protocolos no verifican adecuadamente la identidad de los dispositivos.
  - **Suplantación ARP:** aprovecha la falta de autenticación del protocolo ARP para enviar información de direcciones falsa.
  - **Ataques a DNS:** buscan manipular la resolución de nombres para redirigir a los usuarios hacia direcciones incorrectas.

- **Protocolos obsoletos:** algunas versiones antiguas presentan vulnerabilidades conocidas y mecanismos de protección insuficientes.

- **¿Por qué es importante?**
  - Permite identificar protocolos inseguros dentro de una infraestructura de red.
  - Ayuda a prevenir la interceptación y manipulación de información.
  - Favorece el uso de alternativas seguras, como HTTPS, SSH y versiones actualizadas de TLS.
  - Contribuye a proteger la confidencialidad, integridad y disponibilidad de los datos transmitidos.



FUENTES DE INFORMACIÓN

Atkins, D., & Austein, R. (2004). *Threat analysis of the Domain Name System (DNS) (RFC 3833)*. Internet Engineering Task Force. Recuperado el 20 de octubre de 2026, de https://www.rfc-editor.org/info/rfc3833/

C. Brown. (2024) *What is wireless penetration testing?*, VikingCloud. Recuperada el 20 de octubre de 2026, de https://www.vikingcloud.com/blog/what-is-wireless-penetration-testing

Centro Criptológico Nacional. (2003). *Vulnerabilidades en múltiples implementaciones de Session Initiation Protocol*. Recuperada el 20 de octubre de 2026, de https://www.ccn-cert.cni.es/es/component/vulnerabilidades/view/221.html

Check Point Software Technologies. (s. f.). *How do attackers try to bypass firewalls?* Recuperada el 20 de octubre de 2026, de

https://www.checkpoint.com/cyber-hub/network-security/what-is-firewall/how-to-bypass-firewalls/

Comisión Nacional para la Protección y Defensa de los Usuarios de Servicios Financieros. (2016). *¿Sabes qué es el robo de identidad?* Gob.mx. Recuperada el 20 de octubre de 2026, de https://www.gob.mx/condusef/articulos/recomendaciones-para-prevenir-el-robo-de-identidad

G. F. Lyon, "Fingerprinting methods avoided by Nmap," in *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*, Ch. 8, "Remote OS Detection." Nmap.org. Recuperada el 20 de octubre de 2026, de https://nmap.org/book/osdetect-other-methods.html

Gordón Revelo, D. S., & Pacheco Villamar, R. (2018). *Análisis de estrategias de gestión de seguridad informática con base en la metodología Open Source Security Testing Methodology Manual (OSSTMM) para la intranet de una institución de educación superior. ReCIBE, 7*(1), 1-21. Recuperada el 20 de octubre de 2026, de https://www.redalyc.org/journal/5122/512255650001/html/

IBM. (2023). *¿Qué es el pentesting?* Recuperada el 20 de octubre de 2026, de https://www.ibm.com/mx-es/think/topics/penetration-testing

Instituto Nacional de Ciberseguridad. (2022). *SIM swapping: cómo evitar esta estafa*. Recuperada el 20 de octubre de 2026, de https://www.incibe.es/ciudadania/blog/sim-swapping-como-evitar-esta-estafa

Instituto Nacional de Ciberseguridad. (2024). *Spoofing telefónico: cuando la llamada parece legítima*. Recuperada el 20 de octubre de 2026, de https://www.incibe.es/ciudadania/blog/spoofing-telefonico-cuando-la-llamada-parece-legitima

Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales. (s. f.). *Guía para prevenir el robo de identidad*. INAI. Recuperada el 20 de octubre de 2026, de https://home.inai.org.mx/wp-content/documentos/GuiasTitulares/Gu%C3%ADa_Prevenir_RI.pdf

ISECOM. (s. f.). *OSSTMM: Open Source Security Testing Methodology Manual*. Recuperada el 20 de octubre de 2026, de https://www.isecom.org/research.html

Lyon, G. F. (s. f.). *Firewall/IDS evasion and spoofing. En Nmap network scanning.* Nmap.org. Recuperada el 20 de octubre de 2026, de https://nmap.org/book/man-bypass-firewalls-ids.html

MITRE. (s. f.). *Enterprise techniques.* MITRE ATT&CK. Recuperado el 20 de octubre de 2026, de https://attack.mitre.org/techniques/enterprise/

OWASP Foundation. (s. f.). *Credential stuffing*. Recuperado el 20 de octubre de 2026, de https://community.owasp.org/attacks/Credential_stuffing?utm_source

Rescorla, E. (2018). *The Transport Layer Security (TLS) protocol version 1.3 (RFC 8446)*. Internet Engineering Task Force. Recuperado el 20 de octubre de 2026, de https://www.rfc-editor.org/info/rfc8446/

S. Stankovic. (2019). *Firewall penetration testing: Steps, methods, & tools*. PurpleSec. Recuperado el 20 de octubre de 2026, de https://purplesec.us/learn/firewall-penetration-testing/

Scarfone, K., & Hoffman, P. (2009). *Guidelines on firewalls and firewall policy (NIST SP 800-41 Rev. 1)*. National Institute of Standards and Technology. Recuperado el 20 de octubre de 2026, de https://doi.org/10.6028/NIST.SP.800-41r

Scarfone, K., & Mell, P. (2007). *Guide to intrusion detection and prevention systems (IDPS) (NIST SP 800-94)*. National Institute of Standards and Technology. Recuperado el 20 de octubre de 2026, de https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-94.pdf

Temoshok, D., et al. (2025). *Digital identity guidelines: Authentication and authenticator management (NIST SP 800-63B-4)*. National Institute of Standards and Technology. Recuperado el 20 de octubre de 2026, de https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63B-4.pdf